

Artificial Intelligence (AI)

IT Security and Information Governance Policy

This is an Information Security and Governance policy to support future Trust Artificial Intelligence (AI) Policies. The Trust must ensure Confidentiality, Integrity and Availability of Trust data and computer assets when using Artificial Intelligence technology.

Document Detail	
GTi page name	Information Governance Policies
GTi page URL	http://gti/services/infogov/policies.aspx
Sites covered	All sites
Version	1
Approving body	Trust Risk & Assurance Committee
Stakeholder Group	Digital Operations Board (DOB)
Owner	Senior Information Risk Owner
Responsible Lead	Head of Information Security/Head of Information Governance
Effective from	June 2024
Date last reviewed	May 2024
Date of next review	June 2027
Superseded documents	n/a
Related documents	Information Security Policy ; Information Governance Policy ; Third Party Security Policy ; Personal Device (BYOD) policy
Keywords	Artificial Intelligence, Machine Learning, LLM, Chatbot

1 Scope

This policy is for Information Governance and Information Security aspects of Artificial Intelligence (AI) at the Trust. The UK government highlights aspects of infrastructure for AI development and deployment that require assurance. These include¹:

- Training Data
- AI Models
- AI Systems
- Broader Operational Context

The scope of this policy is Information Security and Information Governance within AI systems used at the Trust, to enable a risk-based approach to Artificial Intelligence that fits within the Information Security Policy Framework, Information Governance Policy, and Trust AI requirements.

Some examples of AI enabled systems are listed below, this list is not exhaustive.

- Generative AI - including Large Language Models (LLMs) such as ChatGPT.
 - An LLM is a type of artificial intelligence (AI) program that can recognise and generate text, among other tasks. LLMs are trained on huge sets of data — hence the name "large." LLMs are built on machine learning: specifically, a type of neural network called a transformer model.
- Automated healthcare triage systems
- AI enabled tools (e.g. Microsoft PowerApps/Security enforcing systems and tooling/Chatbots)
- Natural language processing, computer vision, neural networks and distributed artificial intelligence
- AI as a medical device (e.g. where the AI has some functionally diagnostic output that has a dosing implication).

Out of scope: Robotic process automation, which although is non-human based processing, is programmatic, deterministic software and are not generally considered Artificial Intelligence. Information Governance and Security policies still apply.

2 Rationale

Measures are required in the deployment and use of AI, for reasons including but not limited to: ensuring the safety of patients and the public and the protection of their rights; and upholding the Trust's probity with respect to legal obligations and standards of care. AI requires particular attention due to inherent complexities:

"The impact of AI on security depends on the way the technology is built and deployed; the complexity of the organisation deploying it; the strength and maturity of the existing risk management capabilities; and the nature, scope, context and purposes of the processing of personal data by the AI system, and the risks posed to individuals as a result" [ICO]

"UK's approach to AI governance focuses on outcomes rather than the technology itself – acknowledging that potential risks posed by AI will depend on the context of its application." [UK Government]

The Trust must meet security requirements in line with the Trust and NHS information security policy and standards, laws and regulations, and contractual obligations. These include:

- UK Government / NHS /Trust policy as applicable to Artificial Intelligence in its various forms.
- UK Government guidance including "Introduction to AI Assurance (Guidance) UK

¹ UK Government guidance "Introduction to AI Assurance (Guidance) UK Government" and Policy Whitepaper

Government” and Policy Whitepaper “A pro-innovation approach to AI regulation”

- Trust Information Security Policy Framework
- General Data Protection Regulations (UK-GDPR) and Data Protection Act 2018
- Computer Misuse Act and Regulation of Investigatory Powers
- Network and Information Systems (NIS) regulations and NHS Data Security and Protection Toolkit (DSPT)
- Contractual agreements between The Trust and its third parties.
- Other accreditations where applicable, such as Payment Card Industry – Data Security Standards (PCI-DSS) and Cyber Essentials (CE/CE+)

3 Policy Objectives

3.1 This policy is intended to:

- Ensure Information Security and Information Governance is embedded for any use of Artificial Intelligence (AI) at the Trust.
- Provide security/governance guidance to any user wishing to use AI tools.
- Ensure only appropriate people will access information across the AI lifecycle.
- Enhance Security Awareness around malicious AI use cases.
 - For example, AI can be used by cybercriminals to generate phishing emails, malicious code, QR codes, deepfake video / audio, malware, internet scraping, to obtain credentials for hacking accounts, exfiltrating sensitive Trust data (e.g. personal, patient or financial information), or to evade detection.
- Embed AI security into the Trust risk management framework.

3.2 This policy does not cover all aspects of the governance and strategic oversight of AI.

Other sources of authority in Trust policy include:

- The Trust's overarching Medical Device Policy and subtending policy documents, govern considerations of AI as a medical device and its governance in use, as aligned with Medical Devices Regulations, including the requirement for CE/UKCA. For example, Trust-developed solutions that are shared with colleagues outside the Trust may constitute 'placing on the market' under the MDR, and therefore require CE/UKCA marking.
- This Trust's R&D policy governs aspects of research applied to AI.

4 Duties

- 4.1 **The Head of Information Security and Risk** will ensure this policy is kept up to date. They are responsible for assurance of technical and organisational security measures at the Trust, and mitigating risks connected with the loss and breach of personal data. They are responsible for risk assessment of and security incident management involving AI solutions in use at the Trust.
- 4.2 **The Trust Data Protection Officer and the Head of Information Governance** have oversight and provides guidance and support for data protection and general information governance advice and guidance and will lead on the provision of specialist support to the organisation on all matters concerning compliance with Information Governance policies, setting standards and ensuring best practice.
- 4.3 **The Information Governance Department** are responsible for reviewing and approving Data Privacy Impact Assessments as part of any new service processes including where a component will allow use of the service on a personal device.
- 4.4 **Directors and Heads of Departments** will ensure that ongoing compliance with this policy is

built into local processes, and that their staff are made aware of their obligations under this policy and associated documentation. They will also ensure that their permanent, temporary staff and contractors are given an appropriate level of access to AI systems used in their department.

- 4.5 **Line Managers** must ensure that staff have access to, are aware and understand the content of this Policy and other relevant documents and enforce their contents.
- 4.6 **All Staff** have a responsibility to for data security and handle any data processed by AI tools appropriately.
- 4.7 **Third Parties** access Trust's information systems comply with this policy. See Third Party Security Policy for further information.

5 Policy Delivery and Implementation

5.1 Documentation of use

- 5.1.1 A system owner (also the named Information Asset Owners (IAO)) must be identified for accountability as identified in the Trust Information Governance and Asset Management Policy.
- 5.1.2 Adoption and deployment decisions must be documented with appropriate records of information processing, decisions made, and risks assessed, mitigated in line with Trust policy. This process must be repeated [periodically, and] in the event that the AI develops beyond the documented tolerances of current documented use and/or current design. This includes Proof of Concept (POC) designs.
- 5.1.3 Data requirements for all AI projects - with respect to the system's intended uses, stakeholders, and the geographic areas where the system will be deployed - must be defined and documented.

5.2 Development

- 5.2.1 All solutions must follow Architecture and Software Development Life Cycle (SDLC) best practice, and a High Level Design (HLD) must be produced.
- 5.2.2 When procuring AI solutions, terms and conditions must be clearly reviewed and ensure that they align with the Trust security standards.
 - Appropriate and relevant Security risk assessments must be completed before procurement.
 - Appropriate and relevant general Information Governance measures must be included in contracts to support the project including relevant DPIAs which must be signed off by Information Governance.
 - Appropriate and relevant Technical security / organisational measures must be included in contracts to ensure security by design. See Trust Third Party Security Policy for further information.
- 5.2.3 When developing AI solutions, Trust policy regarding risk management, data protection, security assurance, vulnerability management and penetration testing applies. See Vulnerability Management Policy for more information.
 - When using AI tools in system development, it must not be assumed that the AI generated code is inherently more secure. Code should be static and dynamically tested to ensure secure coding has been achieved.
 - See Information Governance policies for further general guidance regarding use of Trust data.
- 5.2.4 For further guidance on all Trust-Developed or Third Party solutions, refer to "Introduction to

AI Assurance (Guidance) UK Government” (reference 1, section 9) and Trust AI policy to review aspects of AI systems outside of IG/IS remit including but not limited to:

- Safety and Robustness
- Appropriate Transparency and Explainability
- Fairness
- Accountability
- Contestability and Redress
- Justified Trust
- Benefits e.g. competitive advantage, research, etc.
- Cross-border considerations
- Evaluation and AI Lifecycle including emerging trends
- AI Assurance Landscape including data quality and decision making

5.3 Operation and Monitoring

5.3.1 AI solutions must be monitored for security purposes.

Monitoring methods may be diverse, since “AI solutions” includes technologies ranging from Generative AI - including Large Language Models (LLMs) such as ChatGPT, Open Source systems, and API traffic. Monitoring procedures may include but not be limited to:

- Monitoring for AI specific attacks (e.g. generate phishing emails; malicious code; QR Codes; Deepfakes; malware; scrape internet; to obtain credentials, personal Data or financial information; or evade detection) will be carried out.
 - See Appendix A for information regarding risk assessment and countermeasures.
- Data Loss Prevention (DLP) monitoring will be applied as available, based on Trust data classification, labelling, and in line with records management.

5.3.2 Biometric data for user logins/identification (as defined by UK GDPR Article 4.14) must not be used for any AI technology within Trust-owned solutions. See Reference 8 (section 9 of this document) for further context.

- Personal devices, however, may require extra security. Please refer to the Personal Device (BYOD) policy for recommendations on biometric authentication on a personal device.

5.3.3 Refer to “Introduction to AI Assurance (Guidance) UK Government” and Trust AI policy for further guidance on:

- Managing bias
- Socio-economic implications
- Robot accounts (incl Chatbots)
- Image recognition
- Appendix A and B for additional context

5.3.4 As per the System Access Management Security Policy, AI solutions must have stakeholders who are responsible and accountable for troubleshooting, managing, operating, overseeing, and controlling the system. This typically would be the Information Asset Owner.

5.4 Information Governance and Resilience

5.4.1 Data Processing or Sharing Agreements (DPA) and Data Privacy Impact Assessments (DPIA) must be completed with regards to risk assessment and Data Sharing respectively. This includes but is not limited to documenting how the third party tool obtains, processes

and stores data, who accesses it, when and why. DPIAs require Information Governance sign-off.

5.4.2 Regulatory compliance: All development and procurement must take into account data privacy; consent (& opt out), surveillance concerns [eg.RIPA] data sharing, intellectual property; equality of use; copyright law; FOI; etc.

- Accountability / Audit capabilities, including forensic evidence
- Data destruction/Subject Access Request
- Resilience
- Tools to report inaccurate data
- AI Data classification must be determined along with sensitivity (e.g. Identifiable; Anonymous; Synthetic data)
- Data aggregation risk must be evaluated as an AI tool may enable this tactic to be carried out much more easily than using traditional methods.

5.4.3 Data marked as Sensitive/Highly Sensitive or restricted must not be used in AI solutions unless wholly owned by the Trust and supported by appropriate contractual clauses. Data traceability must be available. Exceptions must be signed off by IG, IS and the IAO.

5.4.4 Ensure transparency regarding collection and processing of data, to include annotation, labelling, cleaning, enrichment, and aggregation.

5.4.5 For existing data sets to train the AI system, colleagues must assess the quantity and suitability of available data that will be needed by the system.

5.4.6 Regarding Large Language Models (LLMs)

- When registering to use an LLM for personal use, staff must not use their work (@gsth.nhs.uk or @nhs.net) email address. Any exception to this can only be done post-DPIA approval, and for defined use case as agreed and documented in the DPIA
- LLMs are trained on massive datasets of text and code, and are still under development. They can sometimes generate incorrect or misleading information that can appear correct.
- LLMs should only be used for tasks that are appropriate for their capabilities.
- LLMs should not be used to make medical diagnoses or to provide medical advice if not approved for use as medical device.
- LLMs should be used in conjunction with other sources of information, such as medical textbooks and clinical guidelines.
- LLMs should be used with caution, and their output should always be verified via human intervention.
- The LLM itself may store and use the information entered into it insecurely or in a country where data protection laws are not in line with UK GDPR, which could lead to risk of GSTT not being compliant with data protection law or NHS value sharing frameworks. Scrutiny must be applied in this respect.
- Under no circumstances should personal identifiable or business sensitive information be entered in to the LLM. Only information that is already available in the public domain should be used. Unless data access and sharing can be appropriately restricted.

5.4.7 Refer to [Information Governance Policies](#) for further information on all wider Information Governance concepts.

5.5 Information Security

5.5.1 AI tooling must never be used to circumvent security controls at the Trust. (For example hacking devices, jailbreak, eavesdropping, etc).

5.5.2 The Trust will perform regular audits and monitoring of public AI tools, including ChatGPT, GenAI and other LLMs to further enhance data security. The Trust may decide to limit

access to these tools to specific employees or teams, based on their job roles and responsibilities.

- 5.5.3 Content filtering may be implemented based on Trust data classification and labelling rules to guard against inappropriate content generated by employees.
- 5.5.4 Any AI integration with Trust systems or using Trust credentials must go through Demand/Non-Standard Demand process and be approved by Information Security.
- 5.5.5 Security tooling may make use AI or Machine Learning, provided that use cases are justified and approved by Information Security. This includes but is not limited to security incident resolution, device management, risk assessment.
 - Where tooling is cloud-based, Trust policies apply.
 - AI security tools must not use Trust data for their machine learning models
 - AI security tools must be supported by a contract between the Trust and the vendor.
- 5.5.6 The Trust must guard against security risks specific to AI solutions, including but not limited to:
 - Personal data of users of the AI system being inadvertently revealed by the outputs of the system itself.
 - Malicious Self-replicating prompts (worms in GenAI ecosystems²) and other GenAI ecosystem compromise
 - Model inversion attacks
 - Membership inference attacks
 - White/Black box attacks
 - Adversarial examples
 - Misinformation spread

5.6 Information Governance and Security Incidents

- 5.6.1 Trust Policy applies. Data breaches involving any AI tool, including Trust developed and third party solutions, must be reported promptly via the Trust Incident Management reporting system (RADAR). This will cascade relevant notification to appropriate groups (e.g. IG and IS)
- 5.6.2 Any request to input Trust data into public tools must be reviewed by IG and IS on a case by case basis, and must be supported by contractual clause within the vendor contract.

Input of Trust sensitive and proprietary data outside of those approved in 5.6.2 into public, free or publicly available AI tools such as ChatGPT or OSINT tools will be considered a data breach.

7 Education and other considerations

There are other considerations which may have an indirect impact on the Trust Information Governance or Information Security landscape.

7.1 Education

The following points apply to staff undertaking internal education courses and as part of their programme are required to submit competency documents and academic writing:

- AI tools have the potential to enhance learning, and can support inclusivity and accessibility when used appropriately. It is important that you understand the potential risks and benefits of these tools if you plan to use them during your studies.
- You may use AI tools like any other resource to help you generate ideas, key themes, and plan your assessment.

² Here Comes The AI Worm: Unleashing Zero-click Worms that Target GenAI-Powered Applications
 Stav Cohen, Ron Bitton, Ben Nassi, Cornell University

- Factual evidence, including quotes and referencing must come from trusted sources.
- Passing off work generated by AI is not acceptable, and will be treated as seriously as plagiarism.
- Some courses or assignments may vary this position. In these cases you will be given detailed instructions on what is and isn't allowed, and may be asked to sign a code of conduct.
- If you are unclear about what is permissible, contact the course lead.

7.2 Other Considerations

- Power consumption used by AI tools may have operational impact.
- Other nations legislation regarding use of AI should also be considered. (EU/US/China etc..) For example, the EU AI Act is referenced in section 9 of this document (reference 5).

8 Do's and Don'ts

- ✗ Under no circumstances should personal identifiable or business sensitive information be entered into a Large Language Model (LLM) or publicly available Artificial Intelligence (AI) solution. This includes but is not limited to: Sensitive information; Patient Information; Staff Information; Intellectual Property; Proprietary Code or proprietary information; Passwords; Keys; credit card numbers or other financial information.
 - Only information that is already available in the public domain should be used, unless data access and sharing can be locked down and guaranteed via contractual clauses.
- ✗ Trust Login Accounts must not be used for public AI tools such as ChatGPT etc.
- ✗ Staff must not use their work (gstt.nhs.uk;rbht.nhs.uk; nhs.net) email address when registering to use an LLM for personal use.
- ✗ Don't assume AI security tooling can replace a zero-trust security strategy; Role Based Access Control and Least Privilege must still apply.
- ✗ Don't install or use a solution that will require an unauthorised change to Trust systems including desktops, firewall rules, etc.
- ✗ Don't install or use a solution that would circumvent Trust policies and standards.
- ✗ Don't integrate any AI technology with Trust systems without the correct due diligence and approval.
- ✓ DO remember that all Trust policies and standards apply to AI solutions, whether they are proof-of-concept (POC) or permanent implementations.
- ✓ Remember that an LLM itself may store the information entered into it insecurely or in a country where data protection laws are not in line with UK GDPR, which put GSTT at risk of not being compliant with UK data protection law. Ensure tools comply with all data protection regulations
- ✓ Always use LLMs with caution.
- ✓ Be aware that LLMs are trained on massive datasets of text and code, are still under development, and they can sometimes generate incorrect or misleading information.
- ✓ LLM output must always be verified via human intervention.
- ✓ Output from LLMs should be validated and correlated with other trusted sources of information. Fact-check all content. False positives and negatives do occur.
- ✓ DO make sure that user Least Privilege and RBAC are incorporated into the solution.
- ✓ Treat the information entered into public AI solutions as if you are posting on a public website.
- ✓ Remember that providers can and do monitor conversations to improve their systems and ensure the content complies with their own policies and safety requirements. There are no known assurances regarding their employees, contractors or partners who may view the information you post. Bear this in mind to prevent a data breach of sensitive information.
- ✓ Use Multi-Factor authentication.
- ✓ AI prompts should be documented and standardised.
- ✓ Ensure that adversarial scenarios are tested against solutions to ensure resilience in the face of manipulative attacks.

- ✓ Do ensure when solutions and POCs are retired that all data models are securely deleted along with the data itself, as per Trust retention and trust data destruction standards. Documentation of these actions must be retained as part of any project.
- ✓ When developing AI, make sure that Disaster Recovery and Resilience is considered at solution design stage.

8 Monitoring and Assurance

Policy Objectives	Monitoring methods	Assurance
Ensure security is embedded for any use of AI at the Trust	SLSP/DPIA	IS/IG
Clarify security requirements for the development and purchase of AI solutions	Non-Functional Requirements	IS/IG
Provide security guidance to any user wishing to use AI tools	Security Awareness materials	IS/IG
Embed AI security into the Trust risk management framework.	Risk Register	IS/IG

9 Document History and References

Document History			
Date	Comments	Author	Approved by
15/04/2024	Final Draft		TRAC June 2024

Document title	Publisher	Date	Comments
1 Introduction to AI assurance	UK Government	February 2024	Guidance
2 A pro-innovation approach to AI regulation	UK Government	August 2023	Whitepaper
3 How should we assess security and data minimisation in AI?	ICO		Guidance
4 A guide to good practice for digital and data-driven health technologies	UK Government	January 2021	Guidance. Superseded by more recent documentation but retained here due to healthcare standards included.
5 Artificial Intelligence Act - briefing	EU Parliament	March 2024	AI Risk assessment
6 Microsoft Responsible AI Standard v2 General Requirements	Microsoft	June 2022	Vendor guidance
7 Countermeasures: the need for new legislation to govern biometric technologies in the UK	Ada Lovelace Institute	June 2022	Independent research institute guidance
8 The AI and Automation Steering Group			See Appendix A